



Curso de

Prevención de Pérdida de Datos

Juan Carlos Parada Gallardo



Objetivo

Acercar y sensibilizar a emprendedores digitales a técnicas y mecanismos de *prevención de pérdida de datos* que pueden implementar en sus negocios para potenciarlos, mejorar su experiencia de usuario y gestionar aquellos riesgos de seguridad que potencialmente puedan afectarlos.

¿Qué es Seguridad de la Información?

¿Por qué hablamos de técnicas de prevención de pérdida de datos?



La Seguridad de la Información: Es un valor estratégico, generador de confianza.

No es solo Infraestructura: Va mucho más allá de la seguridad de los sistemas de información

Es iterativa y resiliente: No solo busca preservar la información sino también permite potenciar los negocios.



La Seguridad de la información busca garantizar

- **Confidencialidad**

La información debe ser accesible sólo a aquellas personas autorizadas

- **Integridad**

La información debe ser completa, exacta e inalterada

- **Disponibilidad**

La información debe poder ser consultada, localizada y/o recuperada cuando se le requiera



¿Por qué hablamos de técnicas de prevención de pérdida de datos?

Porque para garantizar los 3 atributos anteriormente señalados, debemos establecer e incorporar medidas técnicas y tecnológicas de protección que eviten la pérdida o filtración de nuestra información y garanticen la continuidad de nuestro negocio.



Estudio de casos

Riesgos materializados que han
afectado grandes empresas

Las fugas de datos más sonadas del siglo XXI

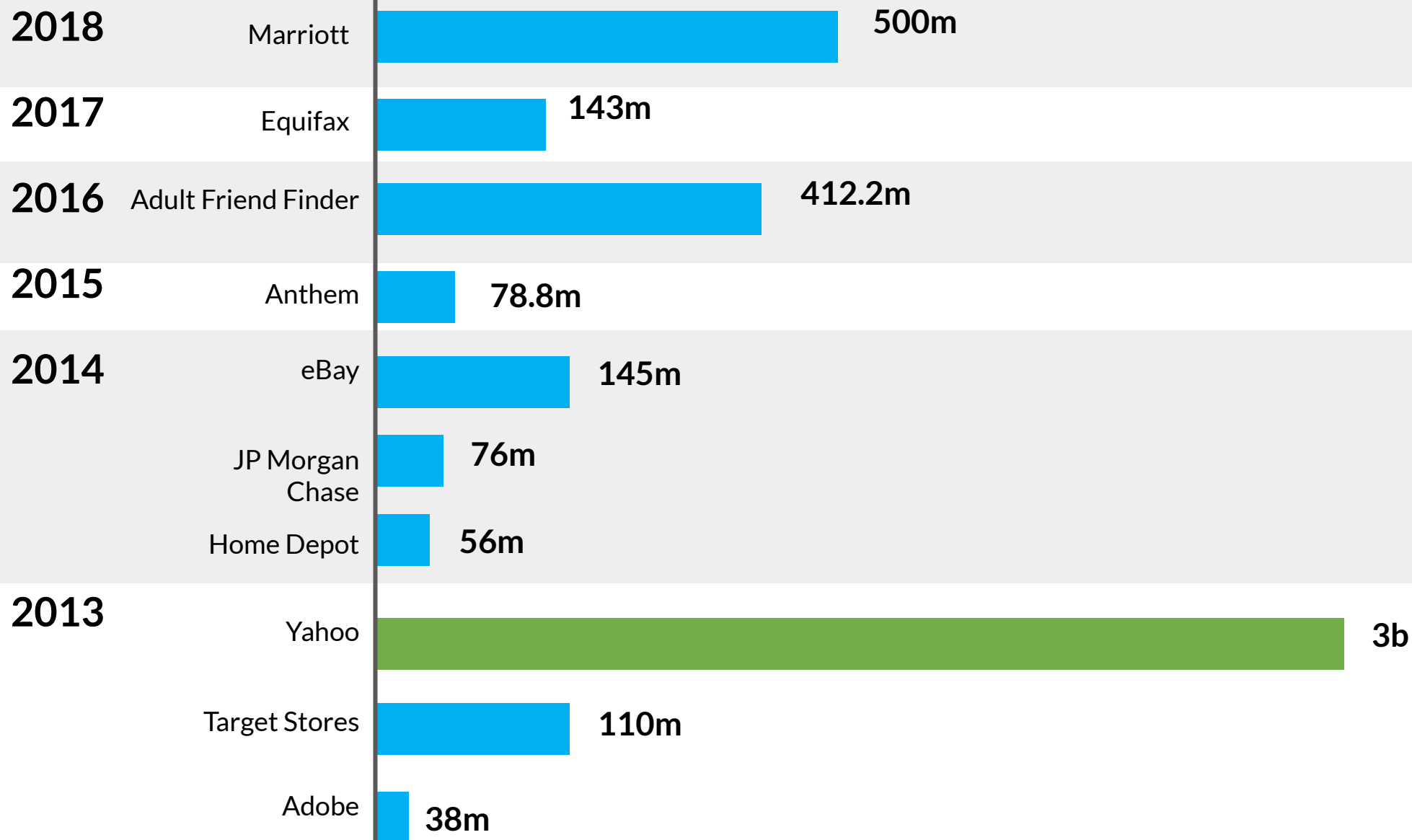




Por millones



Por billones



Fuente: <https://www.csoonline.com/article/2130877/the-biggest-data-breaches-of-the-21st-century.html>



Por millones



Por billones

2012

US Office of
Personal
Management
(OPM)

22m

2011

Sony's
PlayStation
Network

77m

RSA Security

40m

2008

Heartland
Payment Systems

134m

2006

TJX
Companies

94m

Las fugas de datos más sonadas del Siglo XXI



Otros ejemplos



Yahoo

“As we’ve said all along, we will evaluate the situation as Yahoo continues its investigation. V. will review the impact of this new development before reaching any final conclusions.”



Bob Varettoni

@bvar



Here is a screen grab of Verizon's statement about Yahoo's just-issued announcement. [\\$VZ](#) is not commenting beyond this...

♡ 7 16:57 - 14 dic. 2016



[Ver los otros Tweets de Bob Varettoni](#)



Sony



Kaspersky 
@kaspersky



Evidence suggests @Sony hackers are alive & well and still
[#hacking kas.pr/Sony](#) [#infosec](#) [#TheSAS2016](#)

♡ 13 11:01 - 12 feb. 2016

💬 18 personas están hablando de esto



Ciberespionaje

June 18, 2019

Hacking the Russian Power Grid

Attacks by the United States risk escalating a digital Cold War and renew questions about whether certain targets should be off limits in cyber conflict.

Hosted by Michael Barbaro; produced by Eric Krupke and Luke Vander Ploeg, with help from Jessica Cheung; and edited by Larissa Anderson



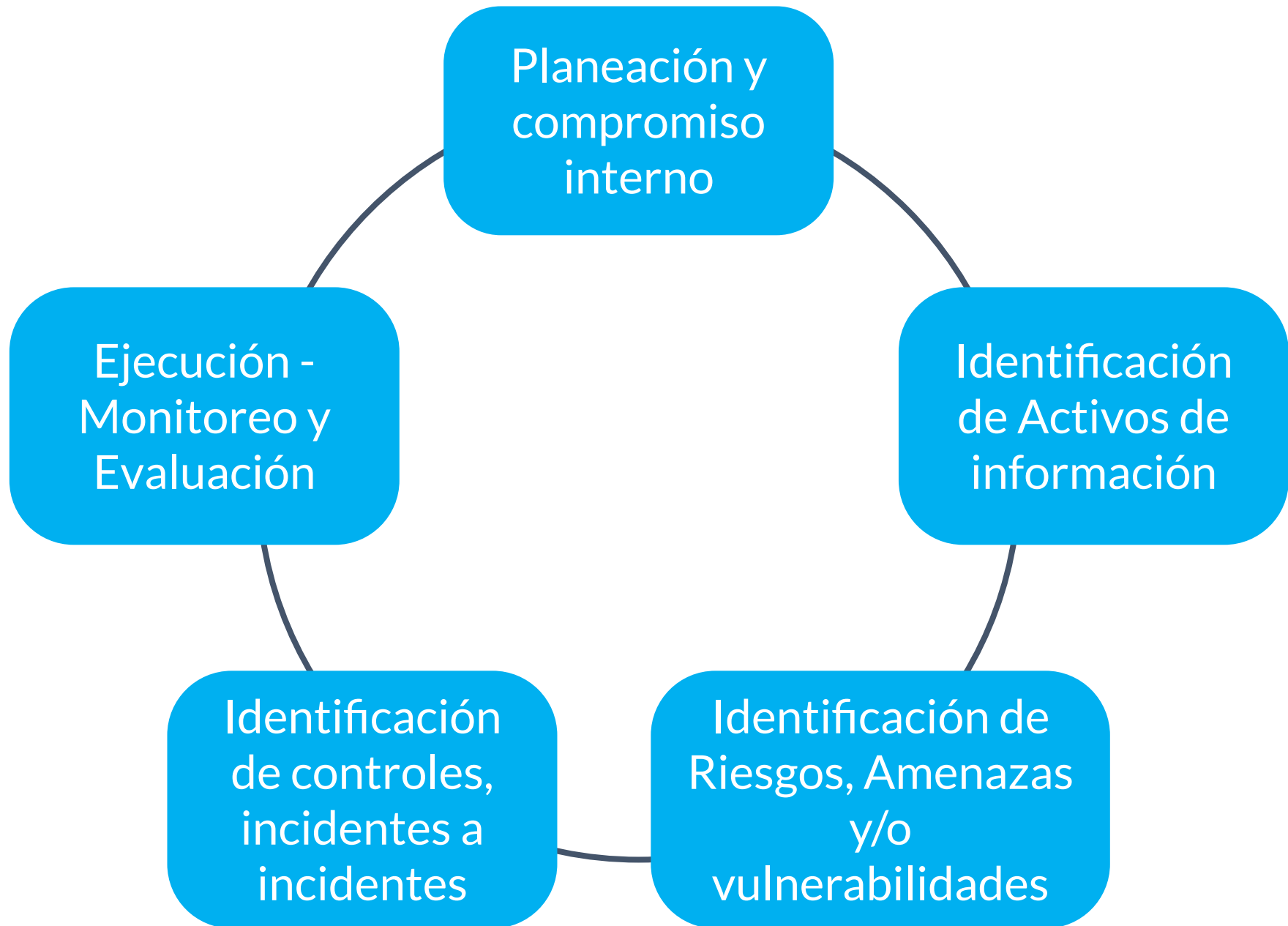
Lecciones Aprendidas

- Ningún sistema es 100 % seguro.
- La Seguridad de la Información debe tratarse con un enfoque estratégico, transversal y preventivo.
- Es necesario siempre considerar el contexto y los comportamientos humanos.
- El liderazgo y la generación de competencias es fundamental para hacer una adecuada gestión de riesgos.

Definiciones

Iniciación: Planeación y Compromiso
Interno para adelantar un proceso de
Gestión de Riesgos de Seguridad

Prevención de Pérdida de Datos a partir de la Gestión de Riesgos de **Seguridad Digital**





ISO 31000:2018 – De Gestión de Riesgos de Seguridad

Fuente: <https://www.iso.org/obp/ui#iso:std:iso:31000:ed-2:v1:es>



Planeación e Iniciación

- Análisis de contexto (Estudio del Negocio)
- Identificación de Actores Internos y Externos
- Compromiso de la Alta Dirección



Definiciones

Activos de Información

Activos de información



¿Qué son los activos de Información?

Los activos de información son, entre otros, las bases de datos, los archivos, los manuales, las aplicaciones, así como el hardware y software que se tiene en una organización para desarrollar su objeto.



¿Cómo identificar Activos de Información?

1. Hacer un inventario de activos
2. Identificar su responsable
3. Determinar su Nivel de importancia
4. Clasificar los activos identificados

Definiciones

Identificación y Gestión de Riesgos

Identificación de Riesgos de Seguridad

Se deben identificar:

1. Tipo de Activos
2. Amenazas
3. Vulnerabilidades
4. Riesgos inherentes a la seguridad digital 

Tipo de activo	Amenazas	Vulnerabilidades	Riesgo
----------------	----------	------------------	--------



Gestión de Riesgos de Seguridad

1. Valoración de los riesgos inherentes a la seguridad
2. Valoración de la probabilidad de ocurrencia
3. Valoración del Impacto
4. Identificación de la Zona de Riesgo

Gestión de Riesgos de Seguridad

5. Definición de Controles

5.1. Definición de Controles específicos para prevenir la Pérdida de datos DLP

5.1.1. Controles en la Recolección

5.1.2. Controles en el flujo de la Información

5.1.3. Controles en el alojamiento y disposición



Gestión de Riesgos de Seguridad

6. Calificación y Evaluación de Controles

7. Gestión y Tratamiento del Riesgo

8. Seguimiento.

Visión

Prevención de pérdida de datos,
una visión estratégica y proactiva,
no solo técnica y reactiva

**Seguridad +
Privacidad**

=

**CONFIANZA
y
CRECIMIENTO**

La Seguridad y Protección de Datos Personales

Una relación que implica algo más
que un cumplimiento legal.

Reglamento Europeo de Protección de Datos (UE) 2016/679 - GDPR)



A partir del 25 de mayo de 2018, con la entrada en vigor del Reglamento general de protección de datos, hay un único conjunto de normas de protección de datos para todas las empresas que operan en la Unión Europea (UE), con independencia de dónde tengan su sede.

Artículo 32 - Seguridad del tratamiento

“Los responsables y el encargados de tratamiento deberán implementar medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:

- a. la seudonimización y el cifrado de datos personales;*
- b. La capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;*
- c. La capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico;***
- d. Un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento”.*



Si bien el reglamento europeo no tiene aplicación directa en Latinoamérica o Estados Unidos, este se está convirtiendo en un estándar internacional, que cualquier emprendimiento digital, con vocación de internacionalización y crecimiento debe considerar.

Visión Europea y Visión Norteamericana

Modelos de Negocios a partir de la
privacidad y el aprovechamiento de la
Información

Procesamiento de Información Personal durante la Segunda Guerra Mundial



Alemania e IBM



USA - Relocation
Centers

Procesamiento de Información Personal durante la Segunda Guerra Mundial



Derecho
Fundamental



Derecho del
Consumidor

Propuesta del Estado de California - AB-375





Responsables

Roles y Responsabilidades

Roles



Líder



Oficiales de
Cumplimiento



Responsables y
encargados

Responsabilidades



Líder



Oficiales de
Cumplimiento



Responsables y
encargados

Cumplimiento y Crecimiento

Recapitulemos

**El Reglamento Europeo de Protección de datos,
incorpora un modelo de protección basado en la
Gestión de Riesgos, que se está convirtiendo en
un estándar Internacional**

**Por lo tanto la Prevención de Pérdida de Datos
dentro de cualquier organización puede darse
en los términos de dicha norma**



La Implementación del GDPR obliga a incorporar técnicas de prevención de Pérdida de Datos, que permiten:

- 1.** Clasificar que tipo de información se tiene e identificar dónde y bajo qué condiciones se tienen almacenados datos personales
- 2.** Monitorear el flujo de los datos y establecer controles de acceso y/o intercambio
- 3.** Borrar o suprimir aquella información que no se requiera o no se necesite.



La Implementación del GDPR obliga a incorporar técnicas de prevención de Pérdida de Datos, que permiten:

4. Restringir y controlar de forma automática el acceso a datos personales por parte de terceros no autorizados
5. Generar alertas automáticas y controles de seguridad que protejan los datos
6. Restaurar la disponibilidad y el acceso a los datos de forma rápida en caso de incidente físico o técnico

Construyamos una política de prevención de pérdida de datos

Es hora de aplicar lo que hemos
visto hasta el momento



Fase 1. Planeación e Identificación

1. Ten claro tu negocio, y los flujos de información
2. Analiza contexto interno y externo
3. Caracteriza tus procesos y procedimientos



Fase 2. Preparación

1. Identificar cuáles son las políticas de gestión y tratamiento que tienes definidas en tu organización
* (Si no las tienes debes Redactarlas)
2. Define Roles y establece responsabilidades
3. Asigna los recursos técnicos, administrativos y económicos necesarios para la implementación



Fase 3. Construcción

1. Identificar tus activos de información
2. Clasifica tus activos e identifica tus infraestructuras Críticas
3. Elabora el listado de activos

Construyamos una política de prevención de pérdida de datos

Evaluación de Impacto de privacidad



Fase 3. Construcción

1. Evalúa tu política de tratamiento de datos y tus controles de Privacidad
2. Realiza una evaluación de impacto de privacidad
3. Define y evalúa tus controles de privacidad

Construyamos una política de prevención de pérdida de datos

Tenemos activos y analisis de Privacidad,
es hora de analizar los Riesgos



Fase 3. Construcción

1. Identifica tus potenciales amenazas y vulnerabilidad
2. Define y valora los riesgos inherentes a la seguridad digital
3. Identifica y evalúa los controles de seguridad que vas a implementar



Fase 3. Construcción

3.1. Define los controles específicos que vas a implementar para prevenir la Pérdida de datos DLP



Fase 3. Construcción

Puedes establecer:

- Controles en la Recolección,
- Controles en el flujo de la Información
- Controles en el alojamiento y frente a la disposición final

Construyamos una política de prevención de pérdida de datos

Ahora conozcamos qué técnicas podemos
incorporar para Prevenir la Pérdida de Datos

Recuerda!!!

Estas técnicas te ayudarán a garantizar la confidencialidad, integridad y disponibilidad de la información, y la continuidad de tu negocio



Técnicas Preventivas

Minimización: (Control de Recolección)

Únicamente trata y recolecta aquellos datos que son absolutamente necesarios para tu objeto de negocio



Técnicas Preventivas

Define Roles (Control de Flujo):

Incorpora reglas de negocio que te permitan controlar los flujos internos a la información, para interrumpir automáticamente cualquier flujo o intercambio no autorizado.



Técnicas Preventivas

Alertas de Detección (Control de Flujo):

Incorpora reglas de negocio que te permitan generar alertas para prevenir el acceso o intercambio de información no autorizada



Técnicas Preventivas

Cifrado de Información (Control de Tratamiento):

Establece reglas para asegurar que la información que se comparta vaya siempre cifrada



Técnicas Preventivas

**Anonimización, Disociación, y Agregación
(Control de Tratamiento):**

Separa los datos del individuo, conviértelos en estadísticas, refínalos y aprovecha esta información



Técnicas Preventivas

Realiza Copias de Seguridad (Control de Disposición):

Define un plan de recuperación y continuidad, realiza copias de seguridad periódicas, y prueba tus mecanismos de recuperación de datos.



Técnicas Preventivas

Control de Actualización (Control de Disposición):

Establece controles o define alertas para prevenir tus herramientas se encuentran desactualizadas, realiza actualizaciones automáticas y capacita a tu personal sobre la importancia de tener tus sistemas actualizados.

Construyamos una política de prevención de pérdida de datos

Documenta y actualiza tu Política



Fase 4. Seguimiento y Evaluación

1. Elabora un plan de auditoria que te permita controlar la efectividad de tu política
2. Asegurate que la alta Dirección participe en el seguimiento y evalúe el desempeño
3. Ten consolidado y actualizado tu reporte de incidentes

Fase 4. Seguimiento y Evaluación

Evalúa tus controles y establece acciones de mejoramiento continuo que te permitan mantener actualizada tu política de prevención.

Gestiona con Resiliencia.



Qué podemos hacer

Responsabilidad, mitigación
y cumplimiento

¿Qué hacer en caso de
materialización de un riesgo
de seguridad o de **pérdida o
filtración de datos?**





Siempre debes:

- Garantizar la cadena de custodia
- Analizar el flujo de información para identificar las causas
- Activar el equipo de gestión de incidentes.
- Informar al usuario y las autoridades*
- Levantar un reporte de incidentes



Recuerda

La responsabilidad es
INSTITUCIONAL!!!

Qué podemos hacer

Cadena de Custodia y contacto con Autoridades



Cadena de Custodia

El concepto de Cadena de Custodia busca *“evitar que los elementos materiales de prueba sean alterados, ocultados o destruidos”*.



Cadena de Custodia

Cada Legislación nacional define sus propios procedimientos.

No obstante, de acuerdo con el estándar ISO 27037:2012 tus controles deben garantizar como mínimo: *la identificación, recolección, guarda y preservación* de las potenciales evidencias, para que sean valoradas por los jueces y las autoridades.



Reporte Autoridades

Cuando ocurra un incidente de seguridad que implique un acceso no autorizado, o la pérdida o filtración de datos personales, debes reportar a las autoridades.

Recuerda la Responsabilidad No es Personal es Institucional!!!



Qué podemos hacer

Lecciones aprendidas



Analiza el contexto: Conoce tu negocio y el entorno, la transformación digital exige innovación y agilidad en todos los contextos

Sé preventivo y no reactivo: Anticipate a los hechos, mantente al día con la evolución del sector y optimiza

Gestiona con resiliencia: No ocultes, identifica las fallas, implementa los controles y evalúa.



Planifica tu Control: Establece un plan de auditoría, que te permite probar la efectividad de tus controles de manera continua e independiente

Documenta los incidentes: Identifica correctamente las causas, y ten presente la información recolectada para formular acciones correctivas o preventivas

Control Estratégico: Involucra a la Alta Dirección recuerda que la gestión de riesgos debe ser un tema estratégico, no netamente operativo



Qué podemos hacer

Métodos de Recuperación
de datos



Debes tener un plan de recuperación y continuidad

Ten siempre un plan B

Esto te ayudará a garantizar la recuperación de tu información y la continuidad de tu negocio



Revisa tus copias de Seguridad: Recuerda debes estar realizando continuamente copias de seguridad y respaldo

Ejecuta los protocolos de Recuperación:
Restaura las copias de seguridad a su estado anterior

Realiza pruebas de hacking ético



Gestiona con Resiliencia

- Conoce el contexto de tu negocio y mantente actualizado
- Identifica las Causas que llevaron a la materialización del Riesgo
- Re evalúa tus vulnerabilidades, Amenazas y califica tus controles
- **Sé resiliente:** Aprende, corrige, evalúa, mejora y potencia tu Negocio



Conclusiones finales

**Seguridad +
Privacidad**

=

**CONFIANZA
y
CRECIMIENTO**



La Seguridad de la Información: Debe entenderse como un valor Estratégico

No es solo Infraestructura: Va mucho más allá de las soluciones de seguridad de los sistemas de información

Es iterativa y resiliente: No solo busca preservar la información sino también permite potenciar los negocios



No existen sistemas o soluciones que sean invulnerables

La clave es realizar una adecuada identificación y gestión de riesgos

Recuerda siempre debes gestionar con Resiliencia. **Anticipate, aprende, corrige, mejora, evoluciona y potencia tu Negocio!!!**

Visión

Prevención de pérdida de datos,
una visión estratégica y proactiva,
no solo técnica y reactiva

**Seguridad +
Privacidad**

=

**CONFIANZA
y
CRECIMIENTO**

GDPR - CCPA

Protección de Datos

Personales

Una relación que implica algo más
que un cumplimiento legal

Reglamento Europeo de Protección de Datos (UE) 2016/679 - GDPR)



Ley de Privacidad del Consumidor del Estado de California - AB-375



El GDPR empezó a regir el 25 de mayo de 2018

La CCPA *empezará* a regir el 1 de enero de 2020

Visión Europea y Visión Norteamericana

Modelos de Negocios a partir de la
privacidad y el aprovechamiento de la
Información

Procesamiento de Información Personal durante la Segunda Guerra Mundial



Alemania e IBM



USA - Relocation
Centers

Diferencias



Derecho
Fundamental



Derecho del
Consumidor

Obligados



Controladores y
Procesadores



Grandes Empresas
Negocios de
Comercio de Datos



Derechos

Art. 15. Acceso (30 días)

Art. 16. Retificación

Art. 17. Eliminación (olvido)

Art. 18. Restricción de Procesamiento

Art. 19. Portabilidad

Art. 21. Objeción

Art. 22. No ser objeto de decisiones automatizadas



Derechos - CCPA

Acceso - (45 días)

Derecho a saber *(se deben informar las categorías de información personal que han vendido o revelado en los últimos 12 meses)*

Eliminación * (Solo directa)

A oponerse a la venta - *Son los consumidores los que deben hacer una exclusión voluntaria (Hacer Click en la opción * No vender)*

A no ser discriminado



Prevención de Pérdida

GDPR

Obliga a realizar Evaluaciones de Impacto de Privacidad

Se debe implementar un modelo de Gestión de Riesgos de Seguridad de la Información

CCPA

Obliga a informar antes de que la información sea recolectada

Se debe implementar controles razonables de seguridad

GDPR - Artículo 32 - Seguridad del tratamiento

“Los responsables y el encargados de tratamiento deberán implementar medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:

- a. la seudonimización y el cifrado de datos personales;*
- b. La capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;*
- c. La capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico;***
- d. Un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento”.*

Enforcement and Private Actions under the CCPA (6-597-4106).

La Ley le otorga la competencia al Procurador General del Estado para investigar y sancionar cuando:

- Se presenten accesos o ventas no autorizadas,
- Filtración de datos,
- Robo o divulgación de información personal no encriptada o no autorizada por el consumidor.

Las multas pueden variar de entre \$ 2.500 por negligencia a \$ 7.500 si se demuestra intención.



Si bien estas normas no tiene aplicación directa en Latinoamérica, se están convirtiendo en un estándar internacional, que cualquier emprendimiento digital, con vocación de internacionalización y crecimiento debe considerar.